



Catch Flag Lab:

MISSION OF THE ROTTEN PEEL

Design, Development, and Pedagogical Analysis of a Gamified Capture-The-Flag Learning Laboratory for Cybersecurity Education

Prepared under the supervision of

Dr. Mohamed Saeed

July 2026

Information Security Analyst (GIZ4_ISS6_S2) odd

Project Team

This project was developed collaboratively by the following team members as part of a cybersecurity coursework submission:

#	Full Name	Role
1	Andrew Beshay Mousa	Team Leader
2	Ahmed Ashraf Ahmed	Team Member
3	Youssef Hany Elshamly	Team Member
4	Mazen Ashraf Basha	Team Member

All team members contributed to the research, design review, and documentation of the Capture-The-Flag learning laboratory described in this report, working under the academic supervision of Dr. Mohamed Saeed.

Table of Contents

1. Executive Summary.....	7
2. Project Idea and Motivation	8
Why a Fun, Narrative-Driven Format.....	8
Target Audience and Intended Use	9
3. The Cyber Kill Chain: Concept, Importance, and Project Mapping.....	9
3.1 What Is the Cyber Kill Chain?	9
3.2 Why the Kill Chain Matters	9
3.3 Dividing This Project Along the Kill Chain	10
3.4 Reading the Mapping.....	11
4. Curriculum: Topics Covered, A to Z.....	11
5. The Story and Design Concept of the CTF.....	14
Narrative Structure Mirrors the Kill Chain	14
Characters as Pedagogical Devices	14
Reward and Closure	15
6. Platform and Instructional Design	15
7. Stage-by-Stage Technical Documentation	17
Stage 1 — Network Port Scanning	17
Technical Concept.....	17
Real-World Relevance	17
Scenario Narrative	17
Learning Outcome.....	18
Stage 2 — HTTP Reconnaissance	19
Technical Concept.....	19
Real-World Relevance	19
Scenario Narrative	19
Learning Outcome.....	19
Stage 3 — File Share Enumeration	21
Technical Concept.....	21
Real-World Relevance	21
Scenario Narrative	21
Learning Outcome.....	21
Stage 4 — SQL Injection.....	23

Technical Concept.....	23
Real-World Relevance.....	23
Scenario Narrative	23
Learning Outcome.....	23
Stage 5 — Spear-Phishing Email Construction.....	26
Technical Concept.....	26
Real-World Relevance.....	26
Scenario Narrative	26
Learning Outcome.....	26
Stage 6 — Password Brute-Forcing.....	28
Technical Concept.....	28
Real-World Relevance.....	28
Scenario Narrative	28
Learning Outcome.....	28
Stage 7 — FTP Server Exploitation.....	30
Technical Concept.....	30
Real-World Relevance.....	30
Scenario Narrative	30
Learning Outcome.....	30
Stage 8 — SSH Access and Steganographic Extraction	31
Technical Concept.....	31
Real-World Relevance.....	31
Scenario Narrative	31
Learning Outcome.....	31
Stage 9 — pfSense Conceptual Knowledge Check.....	33
Technical Concept.....	33
Real-World Relevance.....	33
Scenario Narrative	33
Learning Outcome.....	33
Stage 10 — Firewall Rule Reconfiguration.....	34
Technical Concept.....	34
Real-World Relevance.....	34
Scenario Narrative	34
Learning Outcome.....	34
Stage 11 — Targeted Wordlist Generation.....	35

Technical Concept.....	35
Real-World Relevance.....	35
Scenario Narrative	35
Learning Outcome.....	35
Stage 12 — Targeted SSH Brute-Force.....	36
Technical Concept.....	36
Real-World Relevance.....	36
Scenario Narrative	36
Learning Outcome.....	36
Stage 13 — Data Discovery and Retrieval via SFTP.....	37
Technical Concept.....	37
Real-World Relevance.....	37
Scenario Narrative	37
Learning Outcome.....	37
Stage 14 — Passphrase Discovery via Open-Source Intelligence	38
Technical Concept.....	38
Real-World Relevance.....	38
Scenario Narrative	38
Learning Outcome.....	38
Stage 15 — GPG Decryption and AES-256 Knowledge Check.....	40
Technical Concept.....	40
Real-World Relevance.....	40
Scenario Narrative	40
Learning Outcome.....	40
Stage 16 — Archive Extraction and Evidence Review.....	42
Technical Concept.....	42
Real-World Relevance.....	42
Scenario Narrative	42
Learning Outcome.....	42
Stage 17 — Evidence Submission and Engagement Closure	43
Technical Concept.....	43
Real-World Relevance.....	43
Scenario Narrative	43
Learning Outcome.....	43
8. Tools and Techniques — Consolidated Summary.....	45

9. Mapping to the Objectives Overview	46
Stages 01–03 · Reconnaissance & Enumeration	46
Stages 04–06 · Exploitation & Social Engineering	46
Stages 07–09 · Lateral Movement & Hidden Data	46
Stages 10–12 · Firewalls, Wordlists & Cracking	46
Stages 13–15 · Exfiltration & Cryptography	46
Stages 16–17 · Wrap-Up & Reporting	46
10. Learning Outcomes and Assessment	47
11. Lab Setup Manual — Building This CTF on Your Own Device	48
11.1 Virtual Machines Required	48
11.2 Network Layout and IP Addressing	48
11.3 Mail Server and SPF Configuration (for the Phishing Stage)	49
11.4 Tools Required to Build the CTF	50
11.5 Files and Services Required on Each Server	50
11.6 Simplified Build Steps	51
12. Conclusion	53
13. References	54

1. Executive Summary

This report documents the design, pedagogical rationale, and complete technical content of a purpose-built Capture-The-Flag (CTF) learning laboratory developed to introduce students and cybersecurity beginners to practical offensive-security concepts in an engaging, narrative-driven format. The laboratory, delivered as an interactive, browser-based platform, guides a learner through a simulated seventeen-stage red-team engagement from initial reconnaissance through to final evidence reporting against a fictional target organisation.

Rather than presenting isolated, disconnected exercises, the laboratory is structured around a single continuous storyline in which each technical stage produces the credential, file, or clue required to unlock the next. This design choice sometimes referred to in the serious-games literature as a narrative scaffold was selected specifically to keep beginner learners motivated and oriented across an unusually broad span of the offensive-security kill chain, while still delivering rigorous, individually assessed technical content at every step.

The remainder of this report sets out the motivation behind the project, the full technical curriculum it covers, the narrative and pedagogical design underpinning it, and a detailed stage-by-stage breakdown of all seventeen challenges, concluding with an evaluation of the laboratory's learning outcomes and recommendations for future extension.

2. Project Idea and Motivation

Cybersecurity education faces a well-documented engagement problem: foundational material networking fundamentals, protocol behavior, cryptography theory is often taught in a manner that is technically accurate but disconnected from the excitement that drew many students to the field in the first place. Traditional lecture-based delivery struggles to convey why a concept such as an open SMB port, a weak password, or an unsensitized login form matters in practice, because the consequence of the vulnerability is rarely made tangible to the learner.

The idea behind this project was to design a self-contained, gamified CTF learning lab that closes that gap for students and complete beginners approaching cybersecurity for the first time. Instead of separate, self-contained challenges with no connective thread, the laboratory embeds every technical exercise inside a single ongoing investigative storyline. Each stage's output a password, a username, a hidden file becomes the literal input required to begin the next stage, so learners experience the same information-driven momentum that characterizes a genuine penetration test, while never losing sight of why a given technique matters within the bigger picture.

Why a Fun, Narrative-Driven Format

The platform deliberately wraps its curriculum in an approachable, lightly humorous fictional scenario — a whimsical corporate mystery involving a suspicious company and its erratic leadership — rather than a dry, purely clinical simulation. This is a deliberate pedagogical choice, not a cosmetic one. Gamification research consistently finds that narrative framing, light humor, and a sense of forward progress (visualized in the platform through a persistent progress bar, a 'kill-chain' stage tracker, and short in-character guidance from a mascot figure) measurably increase engagement and completion rates among novice learners, particularly for material that would otherwise feel intimidating or overly abstract.

At the same time, every stage is anchored by genuine, unembellished technical content: a plain-language explanation of the underlying concept, a documented

real-world incident in which the same technique or vulnerability class played a decisive role, outside reference links to primary technical documentation (Nmap's official manual, OWASP cheat sheets, NIST guidelines, and similar authoritative sources), and a concrete hands-on task with a verifiable flag or knowledge check. The narrative is the vehicle; the curriculum underneath it is deliberately rigorous.

Target Audience and Intended Use

The laboratory is designed primarily for undergraduate students, cybersecurity club members, and complete beginners with little to no prior hands-on security experience. Its guided, heavily scaffolded structure hints available on demand, explicit command syntax provided at every stage, and short knowledge checks before high-risk actions such as firewall reconfiguration makes it suitable both for self-paced independent study and for supervised classroom or lab-session delivery.

3. The Cyber Kill Chain: Concept, Importance, and Project Mapping

3.1 What Is the Cyber Kill Chain?

The Cyber Kill Chain is a model originally developed by Lockheed Martin to describe the sequential stages an attacker must successfully complete in order to achieve an objective inside a target network. It breaks a complete intrusion down into seven distinct phases: Reconnaissance, Weaponization, Delivery, Exploitation, Installation, Command & Control, and Actions on Objectives. The model's central insight is that an attack is not a single event but a chain — and, critically, that breaking the chain at any single link is sufficient to defeat the entire attack, regardless of how far along the attacker has already progressed.

3.2 Why the Kill Chain Matters

The Kill Chain is one of the most widely used frameworks in professional cybersecurity for three practical reasons. First, it gives defenders a common vocabulary for describing where, in a multi-stage intrusion, a particular alert or log entry sits — turning a pile of disconnected technical events into a coherent story. Second, it reframes defence as a numbers game in the defender's favour: an attacker must succeed at every single phase, while a defender only needs to reliably detect or block one. Third, it underpins the design of modern detection and threat-intelligence programmes, including MITRE ATT&CK (which expands the same phase-based thinking into a detailed catalogue of real-world techniques) and the SOC playbooks used by security operations teams worldwide to triage incidents.

For a learner, understanding the Kill Chain is arguably more valuable than mastering any single tool covered in this laboratory, because it is the mental model that lets isolated technical skills — a port scan, a brute-force attack, a firewall change — be understood as parts of one coherent offensive process rather than a disconnected list of tricks. This is precisely why the laboratory was structured around it from the outset.

3.3 Dividing This Project Along the Kill Chain

Every one of the seventeen stages documented in Section 7 of this report was deliberately designed to sit within a specific Kill Chain phase, so that progressing through the laboratory is, by construction, equivalent to walking through a complete, realistic intrusion end-to-end. The table below presents this mapping explicitly.

Kill Chain Phase	Corresponding Lab Stage(s)	What the Phase Represents
1. Reconnaissance	Port Scanning (1); HTTP Recon (2); SMB Enumeration (3); OSINT (14)	Identifying live services, exposed information, and human intelligence about the target before any attack is attempted.
2. Weaponization	SQL Injection payload crafting (4); Phishing email drafting (5); Wordlist generation (11)	Preparing the specific payload, pretext, or credential-attack material that will be used against the target.
3. Delivery	Phishing email transmission (5); Submission of the SQLi payload via the login form (4)	Getting the prepared payload or pretext in front of the target, whether a human recipient or a vulnerable input field.
4. Exploitation	SQL Injection execution (4); FTP brute-force (6); SSH brute-force (12); Firewall rule exploitation (10)	Triggering the actual vulnerability or weakness to gain unauthorised access or an unintended outcome.
5. Installation	FTP foothold (7); SSH foothold on Host 2 (8); SSH foothold on Host 3 (13)	Establishing a persistent, reusable access point on a compromised host for continued operations.
6. Command & Control	pfSense administrative access (9–10); Ongoing SSH access across hosts (8, 12–13)	Gaining and exercising standing control over network infrastructure and compromised hosts.
7. Actions on Objectives	Data exfiltration via SFTP (13); Passphrase/decryption (14–15); Evidence extraction (16); Reporting (17)	Achieving the ultimate goal of the engagement: locating, retrieving, decrypting, and formally reporting the target evidence.

3.4 Reading the Mapping

Several points are worth highlighting this mapping.

First, some phases appear more than once throughout the laboratory. For example, **Reconnaissance** is revisited at **Stage 14** through OSINT activities, demonstrating that intelligence gathering is not limited to the beginning of an engagement but continues throughout the attack lifecycle as new information becomes available.

Second, **Weaponization** and **Delivery** are intentionally presented as non-technical, human-centred phases. These stages focus on preparing a payload or crafting a social engineering pretext, followed by delivering it to the target. This emphasizes that not every phase of a cyberattack involves exploiting software vulnerabilities; human interaction is often a critical component.

Third, **Installation** and **Command & Control** are represented using persistent SSH access and administrative control of the **pfSense** firewall rather than traditional malware. This design choice reflects the educational goals of the laboratory, which focuses on demonstrating legitimate protocol abuse and attacker tradecraft instead of malware development, keeping the environment appropriate for beginner-level cybersecurity training.

Finally, **Actions on Objectives** are intentionally distributed across **Stages 13–17** rather than being represented as a single activity. This mirrors real-world engagements, where achieving the final objective—identifying, decrypting, validating, and reporting the required evidence—is typically a multi-step process rather than a single action.

Taken together, this mapping demonstrates that the laboratory teaches more than seventeen independent tools or techniques. Instead, each stage serves as a practical, hands-on illustration of a specific phase of the Cyber Kill Chain, enabling learners to understand both the individual techniques and how they combine to form a complete attack lifecycle.

4. Curriculum: Topics Covered, A to Z

The laboratory is deliberately broad in scope, touching on nearly every stage of the classical offensive-security kill chain rather than focusing narrowly on a single technique. The table below summarises, alphabetically, the full range of technical and conceptual topics addressed across the seventeen stages, with a pointer to where each is covered in depth.

Topic	Where it is Covered in the Lab
Active Directory credential abuse	Concept touched during the phishing / lateral-movement stages, where directory credentials are targeted.
AES-256 Encryption	Block size, round structure, and real-world use — assessed directly in Stage 15.
Asset inventory & cross-referencing	Using an internal asset list to map personal names to system usernames (Stage 7).

Topic	Where it is Covered in the Lab
Brute-force attacks	Automated credential guessing using Hydra against FTP and SSH services (Stages 6 and 12).
Command-line proficiency	Continuous use of Linux/Kali command-line tools throughout all 17 stages.
Digital forensics fundamentals	Archive extraction and evidence review using tar/gzip (Stage 16).
Encryption vs. concealment	Contrasting GPG encryption (Stage 15) with steganography (Stage 8).
Firewall architecture & rule evaluation	pfSense theory and hands-on rule modification (Stages 9 and 10).
FTP protocol weaknesses	Plaintext credential transmission and legacy protocol risk (Stage 7).
GPG / GnuPG symmetric encryption	Passphrase-based decryption workflow (Stages 14 and 15).
HTML source-code inspection	Identifying information disclosure via curl and HTML comments (Stage 2).
Incident evidence handling	Structured evidence of packaging and submission (Stage 17).
John the Ripper rule-based mutation	Generating targeted wordlists from a seed value (Stage 11).
Kill-chain methodology	The full lab is structured to mirror the cyber kill chain, from reconnaissance to reporting.
Lateral movement	Pivoting from an initial foothold to a second, higher-value host (Stages 8, 12, 13).
Multi-factor authentication (as a defence)	Discussed as a mitigation to the brute-force stages.
Nmap port scanning	Foundational reconnaissance and service identification (Stage 1).
Open-source intelligence (OSINT)	Deriving a cryptographic passphrase from public social media research (Stage 14).
pfSense firewall administration	Web-console navigation, rule ordering, and live rule editing (Stages 9–10).

Topic	Where it is Covered in the Lab
Phishing & pretexting	Constructing a spear-phishing email using urgency and authority (Stage 5).
Post-exploitation triage	Searching for a compromised host for anomalous files (Stage 13).
Responsible disclosure	Reporting findings through proper channels rather than public exposure (Stage 17).
SFTP-based secure exfiltration	Encrypted file transfer over an existing SSH session (Stage 13).
SMB enumeration & misconfiguration	smbclient usage and the risk of exposed network shares (Stage 3).
Social engineering psychology	Urgency, authority, and familiarity as manipulation levers (Stage 5).
SQL Injection	Authentication bypass and full-table data extraction (Stage 4).
SSH tunnelling & secure remote access	Reaching an internal-only firewall console through a tunnel (Stage 9).
Steganography	Concealing and extracting hidden data inside an image with steghide (Stage 8).
Threat-actor tradecraft (editing vs. adding rules)	Why attackers modify existing firewall rules to avoid detection (Stage 10).
Username enumeration	Deriving valid usernames from leaked files and asset lists (Stages 3 and 7).
Vulnerability chaining	Combining multiple minor findings (a comment, a share, a password) into full compromise.
Weak/default/predictable passwords	The recurring root cause is exploited across Stages 6, 11, 12, and 15.
Wordlist engineering	Building small, targeted wordlists instead of relying on generic large lists (Stage 11).
Zero-trust principle (by contrast)	Discussed conceptually as the architectural answer to the SMB, FTP, and firewall weaknesses exploited in the lab.

5. The Story and Design Concept of the CTF

The laboratory frames its entire seventeen-stage curriculum inside a single overarching narrative: the learner takes on the role of a newly onboarded security intern at a fictional corporation who, on their very first day, notices that something is deeply wrong with the organization's leadership and internal security posture. What begins as routine reconnaissance work steadily uncovers evidence of a covert, high-level scheme being run by the company's senior executive, compelling the learner to escalate from passive network scanning to a full, methodical investigation culminating in the collection and formal submission of evidence sufficient to expose the plot.

Narrative Structure Mirrors the Kill Chain

The story is not a superficial wrapper; its beats are engineered to align exactly with the professional offensive-security kill chain, so that progressing the plot and progressing the learner's technical skill set are the same act. The investigation opens with reconnaissance and enumeration (Stages 1–3), escalates into exploitation and social engineering (Stages 4–6), advances into lateral movement and hidden-data discovery (Stages 7–9), proceeds through firewall manipulation and targeted password attacks (Stages 10–12), reaches its climax with data exfiltration and cryptographic analysis (Stages 13–15), and concludes with digital forensics and formal reporting (Stages 16–17). A persistent on-screen 'kill-chain' progress bar continuously reflects this structure back to the learner, reinforcing the underlying methodology even as the surface-level story unfolds.

Characters as Pedagogical Devices

Each stage introduces a short, in-character guide figure who frames the upcoming technical concept in plain, conversational language before the learner attempts the task functioning as a low-stakes tutor figure rather than a graded evaluator. Recurring in-story characters (a suspicious senior executive, a compromised staff member whose social-media presence becomes a genuine investigative lead, and the intern-learner themselves) give continuity to the plot and provide a believable

pretext for the specific vulnerabilities being exploited at each stage for example, the executive's over-reliance on personally meaningful, easily guessable passwords is what makes both the wordlist-engineering stage (Stage 11) and the OSINT stage (Stage 14) narratively coherent as well as technically realistic.

Reward and Closure

Upon completion of all seventeen stages, learners are awarded a printable completion certificate that summarizes the tools used and the skills demonstrated throughout the laboratory. The certificate serves as a tangible acknowledgment of achievement and reinforces the practical competencies developed during the exercise.

In addition, learners are presented with a short narrative epilogue that concludes the storyline for each character involved in the scenario. This closing structure is intentionally designed to provide a sense of resolution and closure.

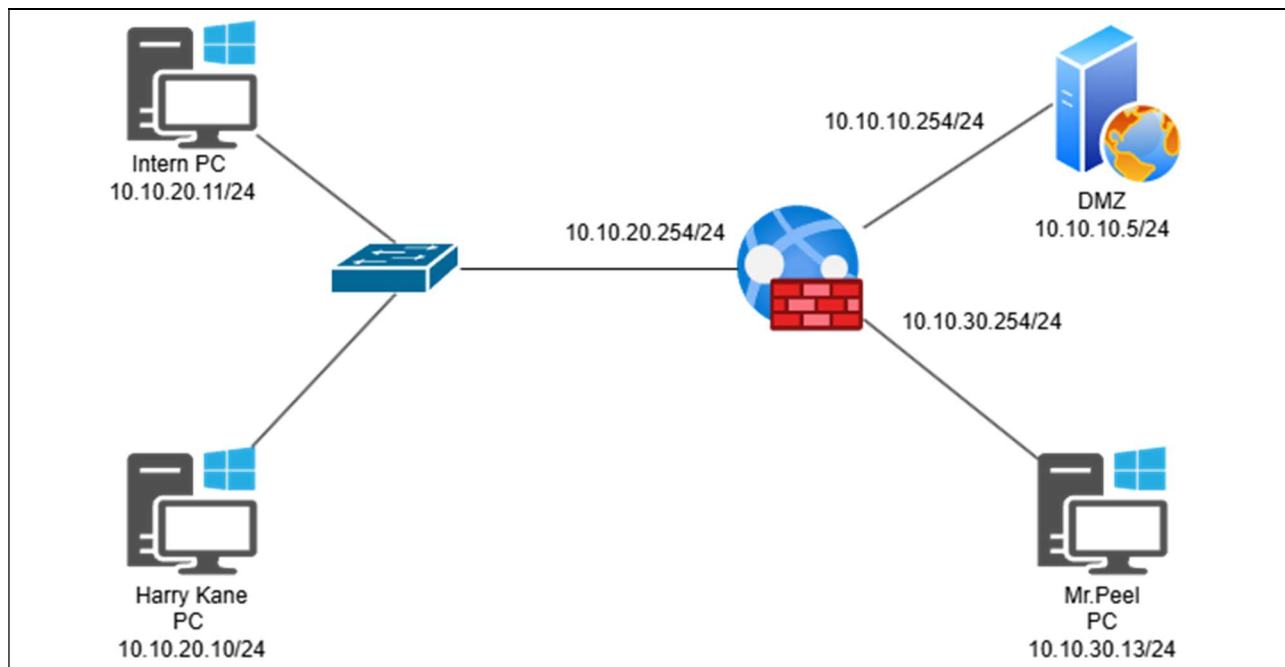
More importantly, it mirrors the outcome of real-world security engagements, where the final deliverable is not merely a list of vulnerabilities, but a comprehensive report that communicates findings, impact, and remediation in a structured and meaningful way.

6. Platform and Instructional Design

Beyond narrative, the platform incorporates several concrete instructional-design mechanisms intended to maximize learning transfer for beginner audiences:

- A persistent sidebar tracking overall mission progress and unlocked stages, giving learners continuous visibility into how far they have come and how much remains.
- A four-part content structure repeated at every stage: a plain-language technical lesson, a documented real-world case study, the in-story scenario justification, and a hands-on task — ensuring theory and practice are never separated.
- On-demand hints at every stage, allowing learners to self-regulate difficulty without being blocked indefinitely by a single obstacle.

- Outside reference links to primary, authoritative sources (official tool documentation, OWASP, NIST, MITRE ATT&CK, CISA advisories) at the end of most stages, encouraging learners to go beyond the guided exercise.
- Interactive knowledge-check stages (Stages 9 and 15) that gate progression behind conceptual understanding rather than a technical flag, ensuring learners cannot bypass foundational theory purely through trial-and-error guessing.
- An extended interactive tutorial embedded in Stage 1 — combining a drag-and-drop matching exercise and a true/false review — that scaffolds complete beginners through core networking concepts before they attempt their first live tool execution.



7. Stage-by-Stage Technical Documentation

The following section documents each of the seventeen stages of the laboratory in full: its phase within the overall kill chain, the tool or technique it teaches, its explicit learning objective, the underlying technical concept, a real-world case demonstrating the concept's practical significance, the in-story scenario justifying the task, and the learning outcome the stage is designed to produce.

Stage 1 — Network Port Scanning

Phase / Category	Reconnaissance
Primary Tool(s)	Nmap
Learning Objective	Discover which network services are exposed to the target host by identifying all open TCP ports.

Technical Concept

Nmap (Network Mapper) is the foundational reconnaissance tool for any penetration test. It probes a target IP across its 65,535 possible ports and reports each port's state open, closed, or filtered along with the service and version listening behind it (using the -sV flag). Reading the STATE column correctly is the first technical skill every red teamer must master, because every subsequent stage of an engagement depends on knowing which doors are open.

Real-World Relevance

Nmap is used daily by professional penetration testers worldwide and was instrumental in the analysis of the WannaCry ransomware outbreak. It is also the underlying technique behind large-scale internet indexing services such as Shodan. Understanding Nmap output is comparable to learning to read a map before navigating unfamiliar terrain.

Scenario Narrative

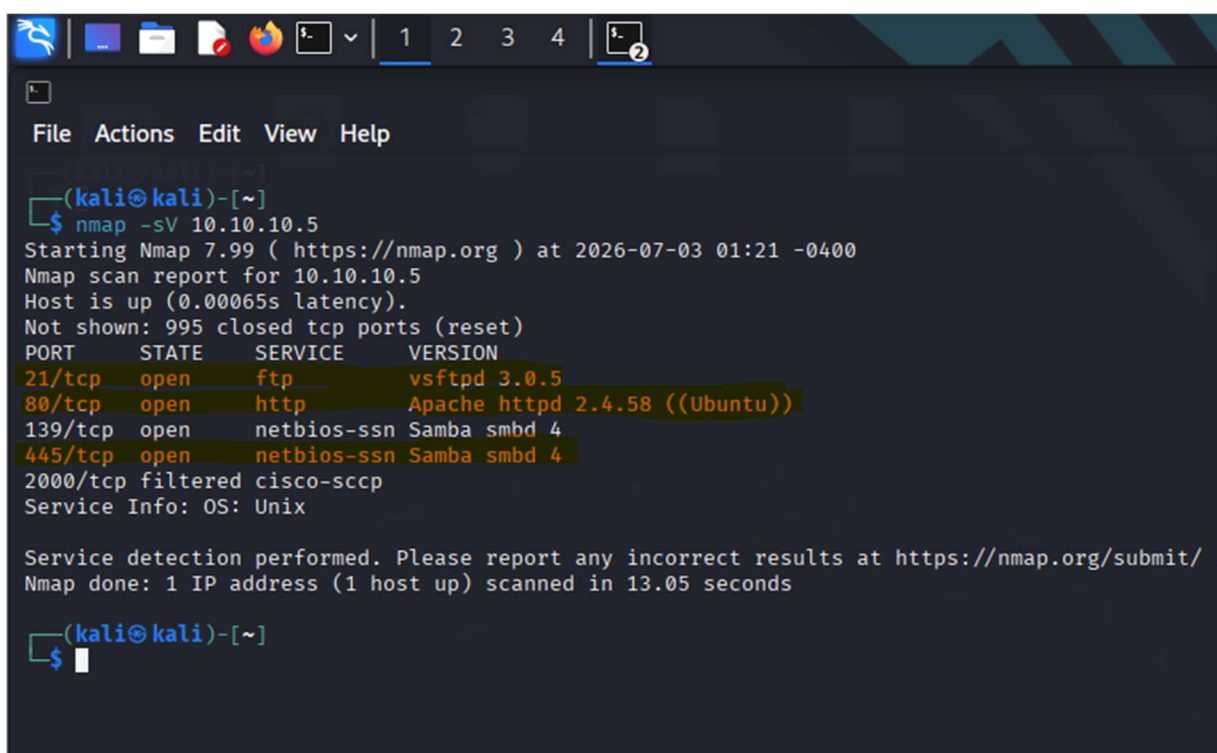
The trainee, newly onboarded as a security intern at the fictional organisation depicted in the scenario, is issued a workstation and network access. As a first, natural step, the trainee performs a port scan of the internal target host and

discovers three exposed services: a web server, a file-transfer server, and a Windows file-sharing service the entry points for the investigation that follows.

Learning Outcome

KEY TAKEAWAY

Learners leave this stage able to run and interpret a Nmap scan independently, understanding port states and the difference between open, closed, and filtered responses. The stage is reinforced with an interactive walkthrough (drag-and-drop port/service matching and a true/false review of legacy versus modern SMB ports) before the learner submits a live flag from their own scan.



```
(kali㉿kali)-[~]
$ nmap -sV 10.10.10.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-03 01:21 -0400
Nmap scan report for 10.10.10.5
Host is up (0.00065s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE  SERVICE      VERSION
21/tcp    open   ftp          vsftpd 3.0.5
80/tcp    open   http         Apache httpd 2.4.58 ((Ubuntu))
139/tcp   open   netbios-ssn  Samba smbd 4
445/tcp   open   netbios-ssn  Samba smbd 4
2000/tcp  filtered cisco-sccp
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.05 seconds

(kali㉿kali)-[~]
$
```

After performing the reconnaissance phase and running an Nmap scan, the results reveal that the target system exposes only three open services: **HTTP (port 80)**, **FTP (port 21)**, and **SMB (port 445)**. These services form the initial attack surface and serve as the starting point for the subsequent stages of the laboratory.

Stage 2 — HTTP Reconnaissance

Phase / Category	Web Enumeration
Primary Tool(s)	curl
Learning Objective	Retrieve the raw HTTP response of the discovered web server and identify sensitive information left in the page source.

Technical Concept

curl is a command-line client for issuing HTTP requests and viewing the exact response returned by a server including HTML comments and metadata that a browser normally renders invisibly. Where Nmap answers WHERE to look, curl answers WHAT is actually there. This stage teaches the learner that the visible web page and the underlying source code are two different attack surfaces.

Real-World Relevance

curl-based enumeration underlies bug-bounty hunting, API testing, and server fingerprinting. The 2020 Twitter account-takeover incident began with attackers enumerating internal administrative tooling through exactly this kind of manual web reconnaissance.

Scenario Narrative

With the web service identified in Stage 1, the trainee requests the raw HTML of the corporate site. Buried inside an HTML comment the kind developers routinely forget to remove is a credential for the file-sharing service discovered earlier, illustrating how information disclosure vulnerabilities commonly originate from careless developer habits rather than sophisticated attacks.

Learning Outcome

KEY TAKEAWAY

Learners understand that source-level inspection is a distinct discipline from browsing, and that HTML comments are a genuine, frequently exploited information-disclosure vector documented by OWASP.

```
File Actions Edit View Help
# I discovered something dangerous.
#
# Mr. Peel and most of the company...
# they are NOT who they seem to be.
#
# They are aliens.
# They have been using this company as a cover --
# controlling people through cryptic bananas.
#
# I know it sounds insane.
# But I saw it with my own eyes.
#
# They tried to force me to eat one.
# I refused.
#
# _____
#
# Now they know that I know.
# I don't have much time left.
#
# So I am leaving pieces of evidence at every stage.
# Follow the trail. Find the proof.
# Please stop them.
#
#   T h e   w o r l d   d e p e n d s   o n   y o u .
#
# _____
#
#           ███ FINAL GIFT ███
#
# Before they find me -- here is what you need
# to get into their system:
#
#   SMB User      : samba
#   SMB Password  : lets_dance_samba
#
# Use it wisely.
# Don't let them see you coming.
#
# _____
#
#                                     -- Andrew
#                                     Banana Co. Intern
#                                     [WHEREABOUTS UNKNOWN]
#
# [ This message will not be here much longer. ]
```

After running the `curl` command, you will discover a hidden message embedded within the web server's main page. The message introduces a new character, **Andrew**, a former intern who previously investigated Banana Co. Like the learner, Andrew attempted to understand the company's activities and uncover what Banana Co. was really trying to accomplish. This message serves as the first narrative clue and encourages learners to continue their investigation and Form this stage we will get **SMB server** username and Password that we will use it to investigate more.

Stage 3 — File Share Enumeration

Phase / Category	SMB Enumeration
Primary Tool(s)	smbclient
Learning Objective	Authenticate the exposed SMB file share using the harvested credential and locate a second, more valuable credential inside it.

Technical Concept

SMB (Server Message Block) is the protocol Windows systems use to share files and printers across a network. smbclient is the Linux command-line equivalent of Windows File Explorer for browsing such shares. A very common real-world weakness is that SMB shares are left accessible to any authenticated (or even guest) user, exposing far more than intended.

Real-World Relevance

An SMB vulnerability (Eternal Blue) was the propagation mechanism behind WannaCry, which infected roughly 230,000 machines across 150 countries in a single day, and the related Not Petya attack, which caused an estimated \$10 billion in global damage.

Scenario Narrative

Using the credential harvested from the web server's HTML comment, the trainee connects to the SMB share and finds a directory of internal files staff lists, internal memos, and a plaintext file naming the username for the organization's FTP service, illustrating the danger of storing operational credentials inside shared network folders.

Learning Outcome

KEY TAKEAWAY

Learners come away understanding why SMB misconfiguration remains one of the most consistently exploited weaknesses in enterprise networks and gain hands-on practice authenticating to and browsing a network share.

```

(kali@kali)-[~]
$ smbclient //10.10.10.5/MyShared -U samba
Password for [WORKGROUP\samba]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0 Sat May 2 16:12:50 2026
..               D          0 Sat May 2 16:12:50 2026
clue2.txt        A        738 Sat May 2 16:12:50 2026
Gest_Normal_File D          0 Sat May 2 10:25:04 2026
clue1.txt        A        673 Sat May 2 10:21:44 2026

40970464 blocks of size 1024. 20572072 blocks available
smb: \> get clue1.txt
getting file \clue1.txt of size 673 as clue1.txt (73.0 KiloBytes/sec) (average 73.0 KiloBytes/sec)
smb: \> get clue2.txt
getting file \clue2.txt of size 738 as clue2.txt (103.0 KiloBytes/sec) (average 86.1 KiloBytes/sec)
smb: \> cd Gest_Normal_File\
smb: \Gest_Normal_File\> ls
.                D          0 Sat May 2 10:25:04 2026
..               D          0 Sat May 2 16:12:50 2026
.passwords.txt   AH        793 Sat May 2 10:22:55 2026

40970464 blocks of size 1024. 20572072 blocks available
smb: \Gest_Normal_File\> get .passwords.txt
getting file \Gest_Normal_File\passwords.txt of size 793 as .passwords.txt (110.6 KiloBytes/sec) (average 93.6 KiloBytes/sec)
smb: \Gest_Normal_File\> exit

```

After we access the SMB server, we will find three files clue1, clue 2, .password.txt which will help you to learn more info about Andrew, Banana.Co, and cybersecurity Eng “Mr. Harry Kane”.

```

(kali@kali)-[~]
$ cat .passwords.txt
letmein
river
mrfile
duck!
flower
star789
oracle
captain
master
netadmin
charlie
user
garden
secret
peel
azerty
night2024
root
moon456
jordan
corp2024
cisco
alpine
metal
theduck
abc123

```

In file. password we will find out it hidden password database that we will use it in next stages

Stage 4 — SQL Injection

Phase / Category	Exploitation
Primary Tool(s)	SQL Injection payloads
Learning Objective	Bypass an authentication form using a classic SQL injection payload and extract a target employee's contact information from the exposed database.

Technical Concept

SQL Injection occurs when user-supplied input is concatenated directly into a database query without sanitization, allowing an attacker to alter the query logic. The payload ' OR 1=1 -- closes the intended string early, injects a condition that always evaluates true, and comments on the remainder of the query causing the database to return every row instead of validating a single user.

Real-World Relevance

SQL injection has enabled some of the largest data breaches on record, including the 2009 Heartland Payment Systems breach (130 million card numbers), the 2011 Sony PlayStation Network breach (77 million accounts), and the 2015 TalkTalk breach. OWASP has ranked injection among its top web application risks in every edition of its Top Ten.

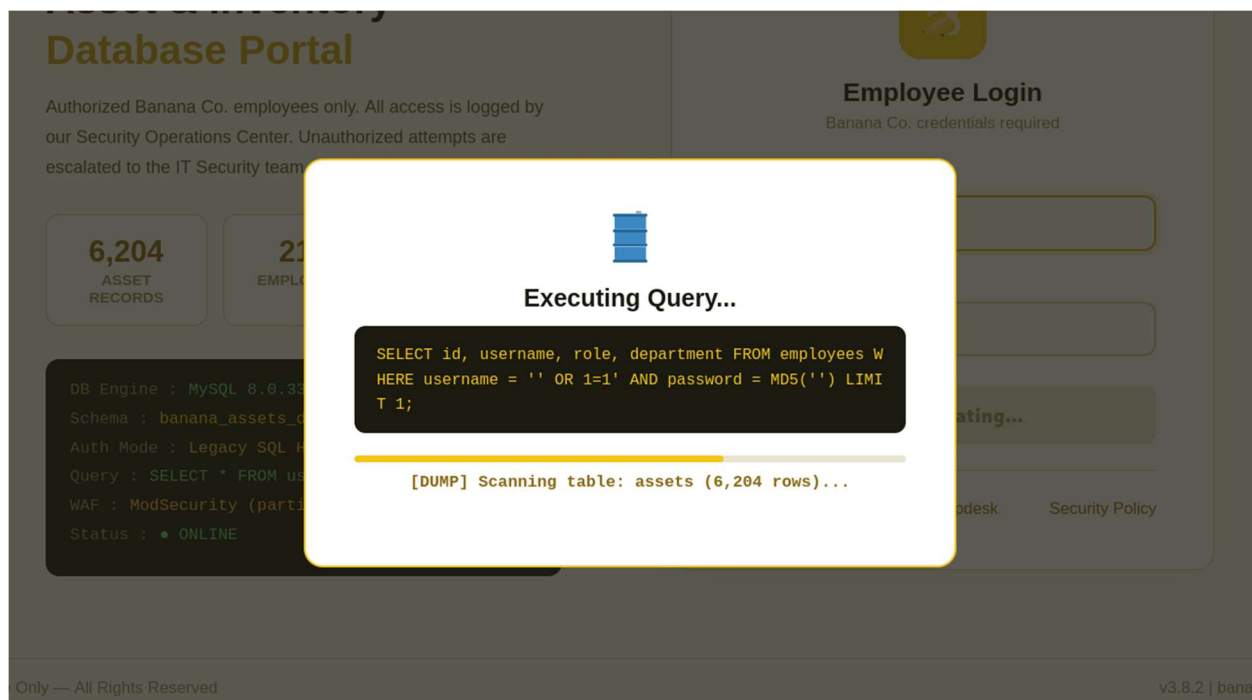
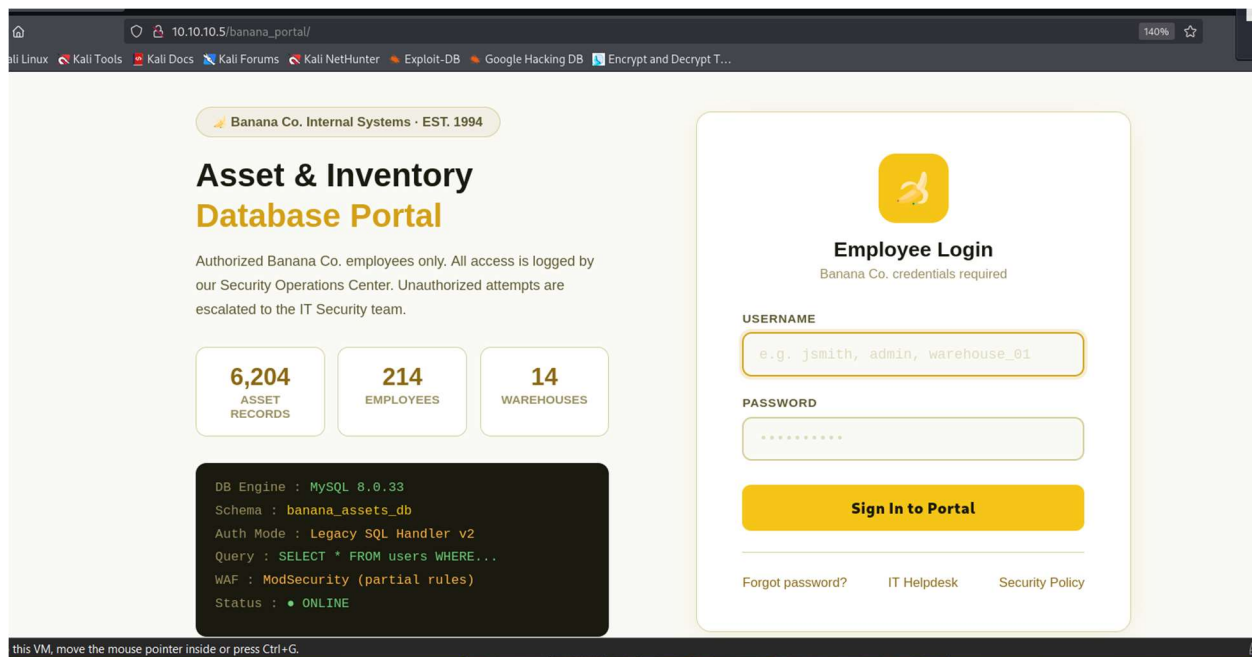
Scenario Narrative

The trainee locates an employee login portal and submits the injection payload in the username field. The query returns to the entire employee table, from which the trainee extracts the personal email address of a senior staff member with the information needed to plan the next stage of the assessment.

Learning Outcome

KEY TAKEAWAY

Learners practise a canonical, historically significant exploitation technique and directly observe why input validation and parameterized queries are non-negotiable for secure-coding requirements.



ID	Machine Nam	IP Address	Gateway	Device Owner	Host name	S/N	Job Title	Contact
4221	F1-C4221	10.10.10.5	10.10.10.254	Koki Hanem	K.Hanem	BANANA-PC-01A9B7C3	Network Eng	K.Hanemjan@gmail.com
4222	F1-C4222	10.10.10.6	10.10.10.254	Server1	Server1	BANANA-S-013957C3	Device	---
4223	F1-S4223	10.10.10.7	10.10.10.254	Server2	Server2	BANANA-S-01A9B755	Device	---
4224	F2-H4224	10.10.20.5	10.10.20.254	Andrew Beshay	A.Beshay	BANANA-PC-01AAA7C3	Dead	
4225	F2-H4225	10.10.20.11	10.10.20.254	N/A	N/A	BANANA-PC-01A9BCC7	intership	students@gmail.com
4226	F2-S4226	10.10.30.10	10.10.30.254	Al Tebat	A.Tebat	BANANA-PC-01A997C8	HR	A.Tebatfed@gmail.com
4227	F3-B4227	10.10.20.10	10.10.20.254	Harry Kane	harrykane	BANANA-LP-0165B7C3	Cyber Eng	Top Secret
4228	F3-B4228	10.10.20.15	10.10.20.254	Sozy Hanem	S.Hanem	BANANA-LP-58A9B7C3	IT HelpDesk	S.Hanemos@gmail.com
4229	F3-H4229	10.10.20.12	10.10.20.254	Longneck	I.Neck	BANANA-PC-01CVB7C3	Network Eng	LongNeckk@gmail.com
4229	F4-S4229	10.10.30.5	10.10.30.254	Lewis lo Siento	L.I.Siento	BANANA-PC-01UTY7C3	Chicken	CheeseLoverPizza@gmail.com
4230	F4-M4230	10.10.30.13	10.10.30.254	Mr.Peel	Mr.Peel	BANANA-PC-018UB7C3	Manager	Iamnormalhuman@gamil.com
4231	F4-S4231	10.10.30.20	10.10.30.254	Tom Cat	T.Cat	BANANA-LP-01A967C3	HR	meawmeaw@gmail.com
4232	F4-H4232	10.10.30.15	10.10.30.254	Jerry Mousa	J.Mousa	BANANA-LP-01UGE7C3	Sales	cheesecheese@gmail.com

In this stage, learners exploit an SQL injection vulnerability in the Asset Database to retrieve the organization's asset inventory. The extracted asset list provides valuable reconnaissance information, including a hidden reference to **Harry Kane's** email address through his Instagram account. This information is required for subsequent stages of the laboratory and demonstrates how data obtained during one phase of an attack can support later objectives.

Stage 5 — Spear-Phishing Email Construction

Phase / Category	Social Engineering
Primary Tool(s)	Email pretexting
Learning Objective	Draft a targeted, pretext-driven phishing email impersonating a trusted authority figure to induce the target into disclosing credentials.

Technical Concept

Phishing is the practice of crafting a deceptive communication that manipulates a target into an unsafe action. The exercise distinguishes mass phishing, spear-phishing (personalized, uses real details about the target), whaling (targets executives), smishing (SMS-based), and vishing (voice-based). Effective phishing exploits urgency, perceived authority, and familiarity to bypass a target's critical thinking.

Real-World Relevance

Industry research consistently finds that the large majority of cyberattacks begin with a phishing email. The 2016 U.S. election-related breach began with a phishing email to a campaign official, and the 2021 Colonial Pipeline ransomware incident traced back to a single compromised VPN credential obtained through this class of attack.

Scenario Narrative

Having obtained the target's email address, the trainee composes a spear-phishing message impersonating the target's manager, using urgency and authority to instruct the (fictionally, vacationing) target to upload his directory credentials to the organization's FTP server for 'system maintenance' — a classic pretext-driven social-engineering scenario.

Learning Outcome

KEY TAKEAWAY

Learners internalize that the weakest link in most security chains is human decision-making rather than technology, and practice constructing a believable pretext a skill directly transferable to defensive security-awareness training.

```
File Edit Search View Document Help
[Icons]
1 Subject: Where the hell are you, Harry Kane?
2
3 Dear Harry,
4
5 I have reviewed recent security logs and identified suspicious activity originating from an intern's device, including access attempts to SMB shares, HTTP services, and repeated login attempts on the FTP server.
6
7 He is trying to expose us and stop our plan.
8
9 I need you to have access to his PC right now, or I will kill both of you
10
11 You have only 5 min to let me access him.
12
13 Regards,
14 Mr. Peel
15 Master of the World
16
17
18 .....
19 flag(Learning_Fishing)
20
```

This is the formal of phishing email that you will use in this stage to trick harry kane to send it credential on FTP server.

Stage 6 — Password Brute-Forcing

Phase / Category	Credential Attacks
Primary Tool(s)	Hydra
Learning Objective	Use an automated login-cracking tool to brute-force the FTP account password using a wordlist to recover earlier in the engagement.

Technical Concept

Brute-force attacks systematically try candidate passwords until one succeeds. Hydra is a parallelized network login cracker supporting dozens of protocols (FTP, SSH, HTTP, SMB, RDP, and others); given a username and a wordlist, it tests each candidate against the live service at high speed. Standard mitigations include account lockout thresholds, strong, unique passwords, and multi-factor authentication.

Real-World Relevance

The 2012 LinkedIn breach exposed 6.5 million password hashes, the majority of which were cracked within days using automated tools. Modern GPU-accelerated cracking tools such as Hashcat can test billions of password candidates per second.

Scenario Narrative

Following the phishing exercise, the target account is now assumed to have surfaced additional credential material on the FTP server. The trainee runs Hydra against the FTP login using the known username, and the password list recovered from the SMB share in Stage 3, successfully recovering the account password.

Learning Outcome

KEY TAKEAWAY

Learners gain hands-on experience with an industry-standard credential-attack tool and directly witness the practical consequence of weak or reused passwords under automated attack.

```

(kali@kali)-[~]
$ hydra -l mrfile -P .passwords.txt ftp://10.10.10.5
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-03 02:35:34
[DATA] max 16 tasks per 1 server, overall 16 tasks, 109 login tries (l:1/p:109), ~7 tries per task
[DATA] attacking ftp://10.10.10.5:21/
[21][ftp] host: 10.10.10.5 login: mrfile password: duck
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-03 02:35:43

(kali@kali)-[~]
$ ftp 10.10.10.5
Connected to 10.10.10.5.
220 (vsFTPD 3.0.5)
Name (10.10.10.5:kali): mrfile
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||39553|)
150 Here comes the directory listing.
-rw-rw-rw-r 1 770 1003 1831 Apr 30 09:53 id_rsa
drwxrwxrwx 2 1003 1003 4096 Jul 02 16:31 upload
226 Directory send OK.
ftp>

```

This stage we will use the hidden password database that was hidden inside SMB to apply brute force on ftp server and find the password of mrfile user which is “duck” that we will use to access ftp server.

```

(kali@kali)-[~]
$ ftp 10.10.10.5
Connected to 10.10.10.5.
220 (vsFTPD 3.0.5)
Name (10.10.10.5:kali): mrfile
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||39553|)
150 Here comes the directory listing.
-rw-rw-rw-r 1 770 1003 1831 Apr 30 09:53 id_rsa
drwxrwxrwx 2 1003 1003 4096 Jul 02 16:31 upload
226 Directory send OK.
ftp> cd upload
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||27391|)
150 Here comes the directory listing.
-rw-rw-rw-r 1 1003 1003 341 May 02 20:07 Critical Message.txt
-rw-rw-rw-r 1 1003 1003 3504 May 02 20:26 chem_report_1_KCTRL9.txt
-rw-rw-rw-r 1 1003 1003 4107 May 02 20:26 chem_report_2_MusaX.txt
-rw-rw-rw-r 1 1003 1003 4746 May 02 20:26 chem_report_3_MindJuice.txt
-rw-rw-rw-r 1 1003 1003 2134 May 02 20:26 harry_note_to_mrpeel.txt
-rw-rw-rw-r 1 1003 1003 8773 May 02 20:26 photo1_plantation.svg
-rw-rw-rw-r 1 1003 1003 5067 May 02 20:26 photo2_worship.svg
-rw-rw-rw-r 1 1003 1003 7627 May 02 20:26 photo3_factory.svg
-rw-rw-rw-r 1 1003 1003 6933 May 02 20:26 photo4_weird_banana.svg
-rw-rw-rw-r 1 1003 1003 10751 May 02 20:27 photo5_mind_control.svg
226 Directory send OK.
ftp>

```

As you see you will find file called Critical Message that content message between harry kane and his team which content its cerditional.

Stage 7 — FTP Server Exploitation

Phase / Category	Post-Exploitation
Primary Tool(s)	FTP client
Learning Objective	Authenticate to the FTP server, retrieve staged files, and cross-reference an internal asset list to determine a second target system username.

Technical Concept

FTP (File Transfer Protocol, port 21) is an unencrypted, decades-old protocol that transmits usernames, passwords, and file contents in plain text, making it trivially interceptable on an unsecured network — yet it remains common in legacy enterprise environments.

Real-World Relevance

A misconfigured FTP server was implicated in the 2021 breach of a Florida water-treatment facility control system, and FTP-derived credentials have been used to exfiltrate tens of millions of records in major retail breaches.

Scenario Narrative

Using the cracked credentials, the trainee logs into the FTP server and finds a note left by the phished employee containing a password but no username, alongside a company asset list that maps full names to system usernames requiring the trainee to cross-reference the two documents to derive the correct login identity for the next stage.

Learning Outcome

KEY TAKEAWAY

Learners practice data correlation with a core investigative skill and understand why FTP's lack of transport encryption makes it fundamentally unsuitable for handling credentials in a modern network.

Stage 8 — SSH Access and Steganographic Extraction

Phase / Category	Lateral Movement
Primary Tool(s)	SSH, steghide
Learning Objective	Establish SSH access to a second host, locate a suspiciously named directory, and extract data concealed inside an image file using steganography.

Technical Concept

Steganography hides data inside ordinary carrier files such as images, audio, or video. Unlike encryption, which makes data unreadable, steganography makes data invisible. steghide embeds payloads by altering the least significant bits of image pixel values; when no passphrase was used to hide the data, it can be extracted directly with a single command.

Real-World Relevance

Steganographic techniques have been documented in real extremist communications hidden in publicly posted images, and security researchers have identified malware that hid command-and-control instructions inside meme images shared on social media.

Scenario Narrative

The trainee uses the derived username to SSH into the second host and discovers a folder whose name all but announces its contents. Inside is a single photograph; running steghide against it reveals a hidden text flag, illustrating that concealment without genuine access control offers only superficial protection.

Learning Outcome

KEY TAKEAWAY

Learners understand the distinction between confidentiality (encryption) and concealment (steganography), and practice identifying and extracting steganographically hidden data a skill relevant to digital forensics and incident response.

Stage 9 — pfSense Conceptual Knowledge Check

Phase / Category	Firewall Fundamentals
Primary Tool(s)	pfSense documentation
Learning Objective	Demonstrate conceptual understanding of firewall architecture and rule of evaluation before being granted administrative access to a live firewall console.

Technical Concept

pfSense is an open-source firewall and routing platform built on FreeBSD. This stage is deliberately non-technical in execution: rather than performing an action, the learner studies how the web console is reached (via an SSH tunnel into the internal network segment), how firewall rules are evaluated (top-to-bottom, first match wins), and the classification of firewalls (packet-filtering, stateful, proxy/application-layer, and next-generation).

Real-World Relevance

Firewall misconfiguration remains one of the leading root causes of real-world data breaches, including a 2020 incident in which a misconfigured firewall at a major financial institution exposed roughly 100 GB of customer data.

Scenario Narrative

Before being handed administrative access to a production-style firewall, the trainee is required to demonstrate understanding of what a rule change will do reflecting responsible practice in real security operations, where configuration changes are never made without first understanding their consequences.

Learning Outcome

KEY TAKEAWAY

This is a knowledge-validation checkpoint rather than an exploitation stage: three multiple-choice questions must be answered correctly before progression, reinforcing retention of firewall theory ahead of hands-on practice.

Stage 10 — Firewall Rule Reconfiguration

Phase / Category	Command & Control
Primary Tool(s)	pfSense web console
Learning Objective	Using administrative access, locate an existing rule blocking traffic to a restricted network segment and change its action from Block to Pass.

Technical Concept

pfSense rules are evaluated top-to-bottom, and the first matching rule wins meaning a higher, pre-existing BLOCK rule will silently override anything added beneath it. The correct remediation (or, from an attacker's perspective, exploitation) is often to edit the existing rule rather than add a new one.

Real-World Relevance

Attackers who compromise firewall credentials frequently modify existing rules rather than creating new ones, since this is quieter and more easily missed during a security audit precisely the behaviour this stage simulates.

Scenario Narrative

With administrative access to the firewall, the trainee finds a pre-existing rule blocking all traffic to the restricted executive network segment. Rather than adding a new rule, the trainee edits the existing rule action from Block to Pass, granting access to the previously isolated segment.

Learning Outcome

KEY TAKEAWAY

Learners understand rule-ordering logic in stateful firewalls and the audit-evasion implications of modifying existing configuration versus adding new configuration a subtlety often missed by less experienced practitioners.

Stage 11 — Targeted Wordlist Generation

Phase / Category	Password Cracking
Primary Tool(s)	John the Ripper
Learning Objective	Generate a small, highly targeted password wordlist by applying rule-based mutations to a personal detail associated with the next target.

Technical Concept

John the Ripper's rules engine applies transformation rules to a base wordlist — capitalising the first letter, appending digits, substituting characters (a→@, e→3, o→0), reversing strings, and hundreds of similar mutations — turning a single seed word into a large set of realistic password candidates.

Real-World Relevance

John the Ripper has been in continuous use since cracking the first Unix password hashes in 1997, and was used to crack roughly 90% of the 6.5 million password hashes exposed in the 2012 LinkedIn breach within a single week.

Scenario Narrative

Knowing the target's name, the trainee seeds a base wordlist with that single piece of personal information and lets John's rules engine expand it into a small set of realistic candidate passwords, ready for use in the following brute-force stage.

Learning Outcome

KEY TAKEAWAY

Learners understand why targeted, information-driven wordlists dramatically outperform large generic wordlists in real attacks, reinforcing the risk of using personally identifiable information as password material.

Stage 12 — Targeted SSH Brute-Force

Phase / Category	Lateral Movement
Primary Tool(s)	Hydra
Learning Objective	Use the wordlist generated in the previous stage to brute-force the SSH credential of a senior target account.

Technical Concept

This stage demonstrates that a small, well-targeted wordlist can succeed in seconds where a large generic wordlist would take far longer, because SSH's cryptographic handshake makes each individual login attempt comparatively slow — reinforcing the lesson that attack efficiency depends on intelligence quality, not just computational power.

Real-World Relevance

The 2014 celebrity iCloud breach ('Celebgate') used exactly this targeted password-spraying approach — attacker-curated wordlists built from personal details — to compromise roughly 500 accounts.

Scenario Narrative

The trainee runs Hydra against the target's SSH service using the compact, personally-tailored wordlist from Stage 11 and recovers a weak password based directly on the target's own name — demonstrating how personal predictability defeats even a supposedly security-conscious individual.

Learning Outcome

KEY TAKEAWAY

Learners connect password-policy theory to a concrete, fast, successful attack, reinforcing why organisations enforce complexity and uniqueness requirements independent of a user's seniority.

Stage 13 — Data Discovery and Retrieval via SFTP

Phase / Category	Exfiltration
Primary Tool(s)	SFTP
Learning Objective	Using the newly obtained SSH credential, search the target host for unusual files and retrieve an encrypted archive over an encrypted transfer channel.

Technical Concept

SFTP (SSH File Transfer Protocol) rides over an existing SSH session, so file transfers are encrypted end-to-end — in contrast to Stage 7's plaintext FTP. Post-exploitation practice typically involves searching for anomalies: oddly named folders, hidden directories, and encrypted archives that stand out from routine files.

Real-World Relevance

In the 2020 SolarWinds supply-chain compromise, attackers used legitimate file-transfer mechanisms to quietly exfiltrate data over an extended period, specifically searching for unusual archives containing source code and credentials — the same investigative pattern practised in this stage.

Scenario Narrative

The trainee authenticates via SSH to the senior target's machine and, while enumerating the file system, discovers a folder with a conspicuously defiant name. Inside is a GPG-encrypted, compressed archive, which the trainee retrieves securely over SFTP for offline analysis.

Learning Outcome

KEY TAKEAWAY

Learners practise systematic file-system triage during post-exploitation and understand why anomaly-based searching (rather than exhaustive manual review) is the practical standard in real engagements and incident response.

Stage 14 — Passphrase Discovery via Open-Source Intelligence

Phase / Category	Cryptography / OSINT
Primary Tool(s)	OSINT (public social media)
Learning Objective	Use open-source intelligence gathering techniques to determine the passphrase protecting the encrypted archive retrieved in the previous stage.

Technical Concept

This stage reframes cryptography as fundamentally a human-factors problem: GPG's mathematics are not being attacked; the goal is to discover what a real person chose as a memorable passphrase. A clue recovered earlier points to something the target 'loves' — directing the trainee toward the target's public social media presence as an intelligence source.

Real-World Relevance

In the well-known 2016 Reality Winner case, encrypted documents leaked from a classified environment were ultimately traced back to a passphrase discoverable through personal information — a reminder that the weakest link in cryptography is consistently the human who selects the key material, not the algorithm.

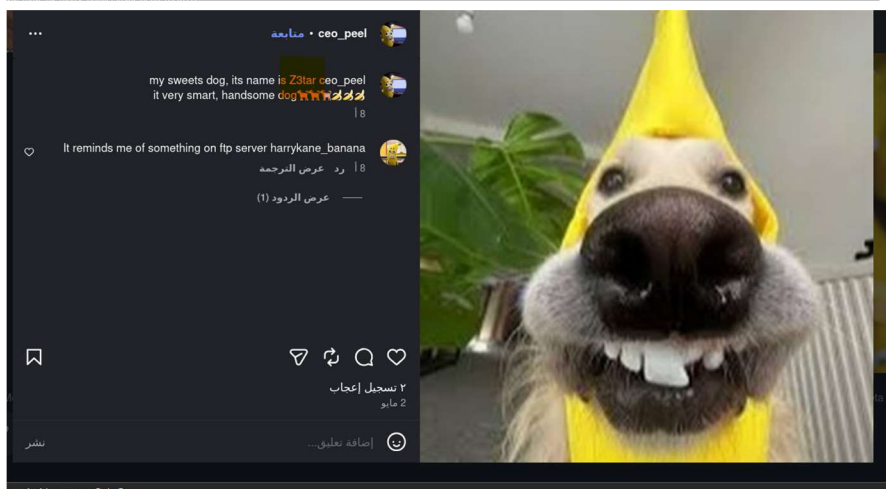
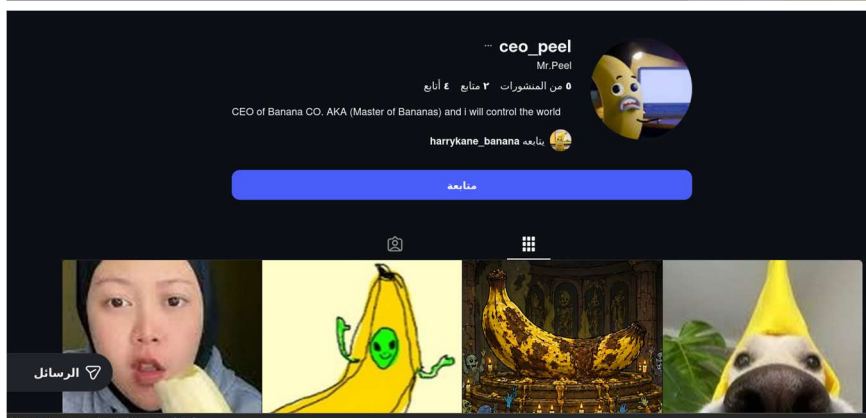
Scenario Narrative

Recalling an earlier clue that the archive's passphrase relates to something the target 'loves more than anything else,' the trainee searches the target's public social media account and identifies the recurring name of the target's pet — the correct passphrase.

Learning Outcome

KEY TAKEAWAY

Learners practise structured open-source intelligence gathering and directly observe the gap between theoretically unbreakable cryptography and practically guessable human-chosen keys.



In the previous stage, learners discovered that **Harry Kane** encrypted a file using the name of his favourite animal as the password and left a note indicating that only **Mr. Peel** would know it. In this stage, learners apply open-source intelligence (OSINT) and social engineering techniques to investigate Harry's online presence and identify the password. Through this investigation, they discovered that Harry's dog is named **Z3tar**, which serves as the password required to decrypt the encrypted file and progress to the next stage of the laboratory.

Stage 15 — GPG Decryption and AES-256 Knowledge Check

Phase / Category	Decryption
Primary Tool(s)	GnuPG (GPG)
Learning Objective	Decrypt the retrieved archive using the discovered passphrase, then demonstrate conceptual understanding of the AES-256 algorithm underlying GPG's symmetric encryption.

Technical Concept

GPG's symmetric mode defaults to AES-256, which operates on 128-bit blocks under a 256-bit key across 14 transformation rounds and is considered computationally infeasible to brute-force with current or foreseeable technology. This stage pairs a practical decryption action with a short assessment confirming the learner understands why the algorithm itself was never the weak point.

Real-World Relevance

AES-256 secures classified government communications, protects the HTTPS connection behind nearly every website, underlies full-disk encryption systems such as BitLocker and FileVault, and secures messaging platforms including Signal and WhatsApp.

Scenario Narrative

Armed with the passphrase recovered through OSINT, the trainee decrypts the archive and is presented with three short questions on AES-256 fundamentals (block size, round count, and its true real-world weak point) that must be answered correctly to proceed — no additional flag submission is required for this stage.

Learning Outcome

KEY TAKEAWAY

Learners consolidate their understanding that a cryptographically strong algorithm provides no protection if the human-selected key material is weak — the central theme connecting Stages 14 and 15.


```

(kali@kali)-[~/Desktop]
$ gpg -d You_Will_Never_Get_Me.2.tar.gz.gpg > You_Will_Never_Get_Me.2.tar.gz
gpg: AES256.CFB encrypted data
gpg: encrypted with 1 passphrase

(kali@kali)-[~/Desktop]
$ ls
c2matrix_1.sh  Covenant  'Email phishing.txt'  EvilOSX  FudgeC2  goDoH  ibombshell  merlin  PoshC2  SILENTRINITY  Trevorfuscation  You_Will_Never_Get_Me.2.tar.gz  You_Will_Never_Get_Me.2.tar.gz.gpg

(kali@kali)-[~/Desktop]
$ tar -xzf You_Will_Never_Get_Me.2.tar.gz P
tar: P: Not found in archive
tar: Exiting with failure status due to previous errors

(kali@kali)-[~/Desktop]
$ tar -xzf You_Will_Never_Get_Me.2.tar.gz Desktop/You\ will\ never\ get\ me/

(kali@kali)-[~/Desktop]
$ ls
c2matrix_1.sh  Covenant  Desktop  'Email phishing.txt'  EvilOSX  FudgeC2  goDoH  ibombshell  merlin  PoshC2  SILENTRINITY  Trevorfuscation  You_Will_Never_Get_Me.2.tar.gz  You_Will_Never_Get_Me.2.tar.gz.gpg

(kali@kali)-[~/Desktop]
$ cd Desktop

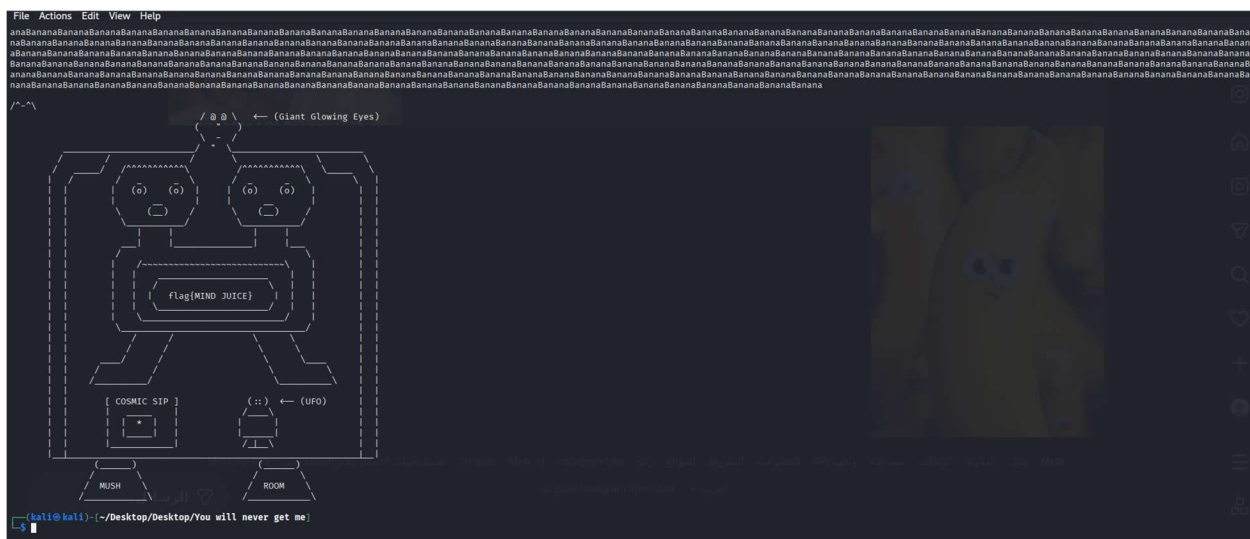
(kali@kali)-[~/Desktop/Desktop]
$ cd You\ will\ never\ get\ me

(kali@kali)-[~/Desktop/Desktop/You will never get me]
$ ls
Big_Flag  Big_Secret  photo_banana_ktrl9.svg  photo_chemical_reaction.svg  photo_mind_juice.svg  photo_mrpeel_world.svg

(kali@kali)-[~/Desktop/Desktop/You will never get me]

```

In this stage, learners decrypt an AES-256 encrypted file using the **GPG** tool. Once the decryption process is completed, the resulting archive is extracted using the **tar** utility. This reveals a collection of files containing critical intelligence information. These files provide key evidence that will be used in subsequent stages to support the investigation and ultimately lead to the arrest of **Mr. Peel**. This stage demonstrates the practical use of cryptographic decryption and archive extraction techniques within a realistic investigative workflow.



This is the **Big Flag**, representing the final objective of the laboratory. After completing all previous stages, learners recover the organization's secret plan: Banana Co. intends to launch a rocket carrying a mysterious substance known as **Banana Juice**. According to the recovered documents, the substance is designed to be dispersed worldwide as part of a plot to control the world's population. Recovering this final document confirms that the investigation has been successfully completed and that the learners have achieved the ultimate objective of the engagement.

Stage 16 — Archive Extraction and Evidence Review

Phase / Category	Digital Forensics
Primary Tool(s)	tar / gzip
Learning Objective	Extract the decrypted archive and identify the internal project codename contained within the recovered documents.

Technical Concept

tar bundles multiple files into a single archive, most often paired with gzip compression (.tar.gz). This stage also introduces the standard operational ordering compress → encrypt (never the reverse), because encrypted data is high-entropy and does not compress efficiently, whereas plaintext structured data does.

Real-World Relevance

Correctly navigating the tar/gzip/gpg chain is a routine requirement in digital forensics and incident response, where recovering readable evidence from encrypted or compressed archives is a core analytical skill.

Scenario Narrative

The decrypted archive unpacks into a set of internal planning documents. Reviewing the extracted material, the trainee identifies the internal codename referenced throughout — the final piece of documentary evidence required before the engagement can be formally closed out.

Learning Outcome

KEY TAKEAWAY

Learners understand the correct order of operations for archiving, compression, and encryption, and gain direct practice extracting and reviewing recovered forensic evidence.

Stage 17 — Evidence Submission and Engagement Closure

Phase / Category	Reporting & Disclosure
Primary Tool(s)	Evidence portal / report submission
Learning Objective	Compile and submit all collected evidence through a formal reporting channel, completing the engagement in line with responsible-disclosure practice.

Technical Concept

Evidence collection and responsible disclosure are the final and, in professional practice, most consequential steps of any security engagement: every finding must be documented, every artefact preserved, and every exploitation path recorded clearly enough for a third party to verify and act on it.

Real-World Relevance

In 2021, a researcher who discovered a critical vulnerability in a contractor supporting U.S. nuclear-arsenal systems documented the finding thoroughly and reported it through proper channels; the vulnerability was patched within 24 hours, illustrating how disciplined evidence handling and responsible disclosure can prevent a genuine security incident.

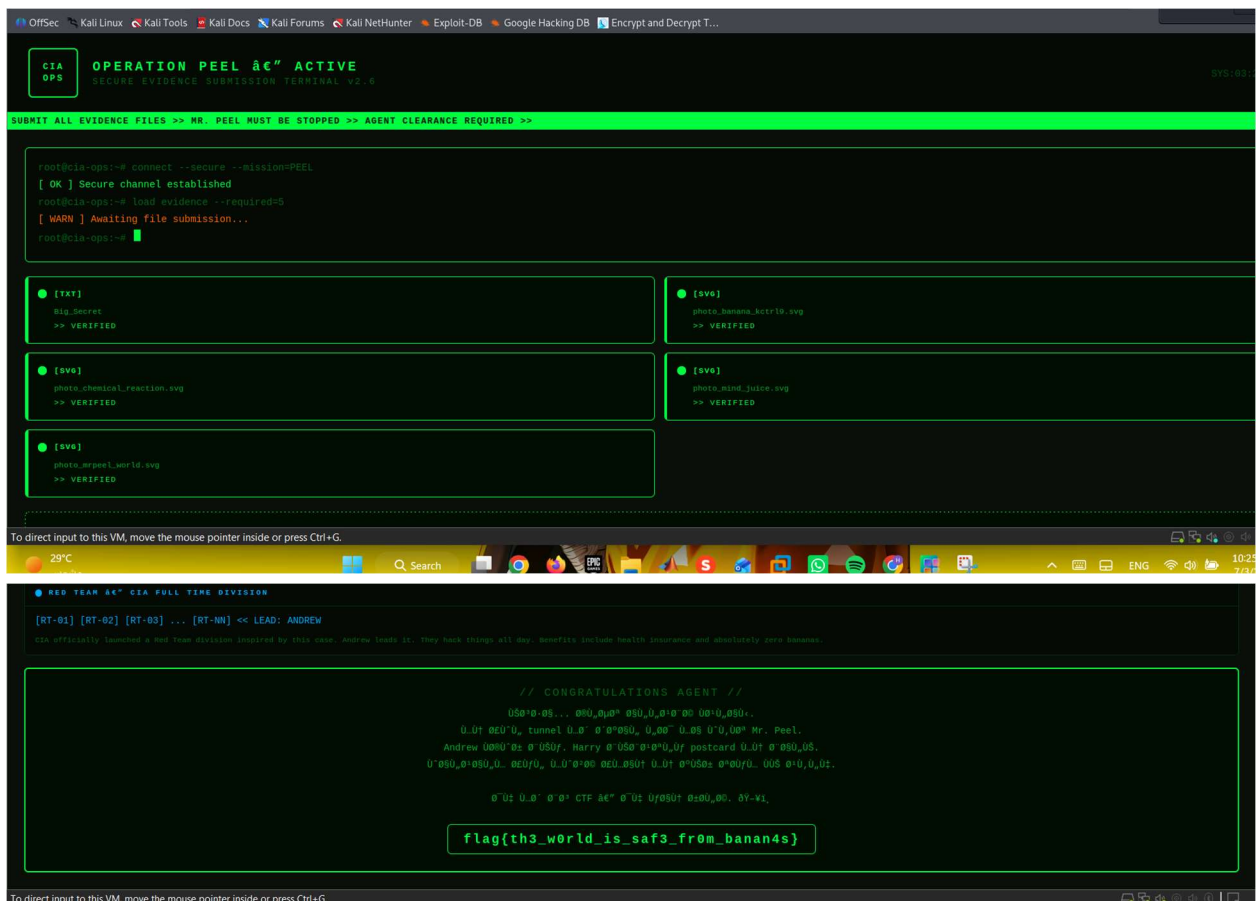
Scenario Narrative

With chemical-formula documents, the deployment plan, and the recovered project files in hand, the trainee submits the complete evidence package through the designated portal, receiving a case reference number that formally closes out the engagement — mirroring the deliverable-driven conclusion of a real penetration test or red-team assessment.

Learning Outcome

KEY TAKEAWAY

Learners finish the laboratory understanding that technical exploitation is only half of professional security work; disciplined documentation and responsible disclosure are what convert a successful technical exercise into an actionable, trustworthy report.



In the final operational stage, learners navigate to the internal URL 10.10.10.5/cia_portal/ and upload the required file to the CIA portal. This action represents the culmination of the investigation, where all previously gathered intelligence is consolidated and submitted. Successful completion of this step signifies that the objective has been achieved, and the system has been secured, effectively concluding the scenario and **“saving the world”** within the context of the laboratory narrative.

8. Tools and Techniques — Consolidated Summary

The table below consolidates every tool and technique used across the laboratory, mapped to the stage(s) in which it appears, providing a quick-reference skills inventory for instructors and learners alike.

Tool / Technique	Function in the Engagement	Stage(s)
nmap	Network scanning & service enumeration	1
curl	HTTP request inspection	2
smbclient	SMB share enumeration	3
Manual SQL injection	Authentication bypass / data extraction	4
Email drafting	Social engineering / phishing	5
Hydra	Automated credential brute-forcing	6, 12
FTP client	File retrieval over plaintext protocol	7
SSH / steghide	Remote access & steganographic extraction	8
pfSense	Firewall administration	9, 10
John the Ripper	Rule-based wordlist generation	11
SFTP	Secure file exfiltration	13
OSINT research	Passphrase / intelligence gathering	14
GnuPG (GPG)	Symmetric decryption	15
tar / gzip	Archive extraction & forensic review	16
Evidence submission workflow	Reporting and responsible disclosure	17

9. Mapping to the Objectives Overview

The platform itself presents learners with a concise objectives overview before they begin the mission, grouping the seventeen stages into six thematic phases. This grouping is reproduced below as it provides a useful, learner-facing summary of scope and progression:

Stages 01–03 · Reconnaissance & Enumeration

Scan a target with nmap, inspect raw web responses with curl, and enumerate exposed SMB shares to locate leaked credentials.

Stages 04–06 · Exploitation & Social Engineering

Exploit a login form with SQL injection, construct a phishing pretext, and brute-force a login using Hydra.

Stages 07–09 · Lateral Movement & Hidden Data

Use FTP and SSH to move deeper into the network, extract hidden data from an image via steganography, and study firewall/tunnelling fundamentals.

Stages 10–12 · Firewalls, Wordlists & Cracking

Reconfigure a pfSense firewall rule, build a targeted wordlist with John the Ripper, and crack SSH credentials.

Stages 13–15 · Exfiltration & Cryptography

Locate and retrieve an encrypted archive over SFTP, discover a GPG passphrase through OSINT, and decrypt it while learning AES-256 fundamentals.

Stages 16–17 · Wrap-Up & Reporting

Extract the final archive with tar, then package and submit evidence — mirroring how a real red-team engagement concludes.

10. Learning Outcomes and Assessment

By the conclusion of the laboratory, a learner who has completed all seventeen stages will have demonstrated practical, hands-on competency across the following domains:

- Network reconnaissance and service enumeration using nmap, curl, and smbclient.
- Web application exploitation, specifically SQL injection against an unsanitised authentication form.
- Social-engineering pretext construction and an understanding of the psychological levers that make phishing effective.
- Automated and rule-based password attacks using Hydra and John the Ripper.
- Legacy and modern file-transfer protocols (FTP and SFTP) and the security implications of each.
- Remote access via SSH, including steganographic data extraction and firewall rule administration via pfSense.
- Applied cryptography, including symmetric GPG decryption and conceptual mastery of AES-256.
- Open-source intelligence gathering as a practical attack vector against weak, human-chosen key material.
- Digital forensics fundamentals, including archive extraction and evidence review.
- Professional evidence handling and responsible disclosure reporting practice.

Each stage is individually and objectively assessed, either through a submitted flag that is validated against a known correct value, or for the two conceptual checkpoints (**Stages 9 and 15**) through a short multiple-choice knowledge check that must be answered correctly before the learner may progress. This dual assessment model ensures that both procedural skill ("can the learner execute the technique") and conceptual understanding ("does the learner understand why the technique works") are verified before advancement, rather than allowing learners to progress on trial-and-error alone.

11. Lab Setup Manual — Building This CTF on Your Own Device

This section is a simplified, practical manual for standing up the laboratory's virtual environment from scratch. It covers the virtual machines required, how they are addressed and networked, the mail/SPF configuration needed for the phishing exercise, the tools used to build each service, and the specific files each server must host. It assumes that a working hypervisor (VirtualBox, VMware Workstation/Player, or Proxmox) is already installed on the host machine.

11.1 Virtual Machines Required

The full laboratory can be built with five virtual machines: one attacker workstation and four target/infrastructure machines, connected across three internal network segments to force the lateral-movement path documented in Section 7.

VM Name / Role	Suggested OS	Network Segment	Suggested Specs	Purpose
Attacker Workstation	Kali Linux	Segment A only	2 vCPU / 4 GB RAM / 40 GB	Runs nmap, curl, smbclient, Hydra, John, steghide, GnuPG, SSH/SFTP clients for all 17 stages.
Web / FTP / SMB Server	Ubuntu Server 22.04	Segment A	2 vCPU / 2 GB RAM / 20 GB	Hosts the vulnerable web portal, vsftpd FTP service, and a Samba share (Stages 2, 3, 4, 6, 7).
pfSense Firewall	pfSense CE	Segments A, B, C (router)	2 vCPU / 2 GB RAM / 10 GB	Routes and filters traffic between all three segments; administered via its web console (Stages 9–10).
Intermediate Host	Ubuntu/Debian Linux	Segment B	1 vCPU / 1 GB RAM / 15 GB	Represents Harry Kane's machine; holds the steganography image and pfSense credentials (Stage 8).
Executive Target Host	Ubuntu/Debian Linux	Segment C	1 vCPU / 1 GB RAM / 15 GB	Represents Mr. Peel's machine; holds the encrypted archive (Stages 12–13).

11.2 Network Layout and IP Addressing

Three internal segments are used, joined together by the pfSense firewall acting as a router between them. Segment C is deliberately blocked from Segment B by an initial firewall rule, which the learner must discover and reconfigure in Stage 10 — this is the single most important piece of network design in the whole lab, so it is worth configuring carefully.

Machine / Interface	Segment	IP Address
Attacker Workstation	Segment A	10.10.20.11 (static)
Web / FTP / SMB Server	Segment B	10.10.10.5 (static)
pfSense (Segment A interface)	Segment A	10.10.20.254 (gateway)
pfSense (Segment B interface)	Segment B	10.10.10.254 (gateway)
Intermediate Host (Harry)	Segment A	10.10.20.10 (static)
pfSense (Segment C interface)	Segment C	10.10.30.254 (gateway)
Executive Target Host (Mr. Peel)	Segment C	10.10.30.13 (static)

- ☐ **Segment A (10.10.20.0/24):** the attacker's own segment; reachable only after credentials are recovered in Stages 1–7; hosts the intermediate SSH target.
- ☐ **Segment B (10.10.10.0/24):** the Web/FTP/SMB server also lives here, so it is reachable without any pivoting.
- ☐ **Segment C (10.10.30.0/24):** reachable only after the firewall rule is changed in Stage 10; hosts the final, highest-value SSH target.
- ☐ The **pfSense VM** should be given three network interfaces (or sub-interfaces), one per segment, and configured to route between them, with an initial rule blocking Segment B → Segment C traffic.

11.3 Mail Server and SPF Configuration (for the Phishing Stage)

Stage 5 asks the learner to draft a phishing email rather than actually deliver one to a live inbox, so a full production mail system is not strictly required. For instructors who want a more realistic version where the drafted email is sent and received inside the lab network, a lightweight internal mail server is recommended, configured as follows:

- ☐ Install a mail transfer agent such as Postfix on a small dedicated VM (or reuse the Web/FTP/SMB server) and create a local mail domain, e.g. banana-co.lab.
- ☐ Add a DNS TXT record for that domain of the form v=spf1 mx a ip4:10.10.10.5 -all, restricting which hosts are permitted to send mail as the domain — this is the SPF (Sender Policy Framework) record itself.
- ☐ Point the domain's MX record at the mail VM's IP address and configure the attacker/learner mail client to relay outgoing test messages through it.
- ☐ This step is optional: if kept simple, the phishing stage can instead be graded purely as a written exercise, with the SPF configuration presented to learners only as a conceptual read-through rather than a live setup.

11.4 Tools Required to Build the CTF

The table below lists the software needed on the build host and across virtual machines. Everything used is free and open source.

Tool	Purpose in the Build
VirtualBox / VMware / Proxmox	Hypervisor to create and run all five VMs.
Kali Linux ISO	Pre-loaded attacker distribution containing nmap, Hydra, John the Ripper, steghide, and GnuPG.
Ubuntu Server ISO	Base OS for the Web/FTP/SMB server and the two internal target hosts.
pfSense CE ISO	Firewall / router appliance used for Stages 9–10.
Apache or Nginx + PHP + MySQL/MariaDB	Hosts the vulnerable login portal used in Stage 4 (SQL Injection).
vsftpd	Provides the FTP service targeted in Stages 6–7.
Samba	Provides the SMB share enumerated in Stage 3.
OpenSSH Server	Enables SSH/SFTP access on the intermediate and executive target hosts (Stages 8, 12–13).
steghide	Used to embed the hidden flag inside the Stage 8 image file ahead of time.
GnuPG (GPG)	Used to pre-encrypt the archive retrieved and decrypted in Stages 13–15.
Postfix (optional)	Lightweight internal mail server for a live Stage 5 phishing-delivery exercise; see Section 11.3.

11.5 Files and Services Required on Each Server

Each server must be seeded with the specific files and services referenced by the corresponding stages, so that the story artefacts a learner discovers to line up with the technical access they have actually gained. The table below summarises what belongs on each machine.

Server	Required Files / Services
Web / FTP / SMB Server	Web root: login page with an HTML comment containing the SMB password (Stage 2); vulnerable SQLi login form and employee database (Stage 4). FTP root: harry_note.txt and asset_list.txt (Stage 7). Samba share: staff list, internal memos, and a plaintext credentials/password-list file (Stages 3, 6).

Intermediate Host (Harry)	A directory with a giveaway name containing the steganography-embedded image (Stage 8); the account's shell history or notes referencing the pfSense console and its credentials.
pfSense Firewall	A pre-configured Segment B → Segment C Block rule under Firewall > Rules > LAN, ready for the learner to locate and edit in Stage 10.
Executive Target Host (Mr. Peel)	A defiantly-named directory containing You_Will_Never_Get_Me.tar.gz.gpg (Stage 13), pre-encrypted with the passphrase used in Stage 14, unpacking in Stage 16 to reveal the project-codename document.
Attacker Workstation	No pre-seeded files are required; it should ship clean, with only the standard Kali toolset installed.

11.6 Simplified Build Steps

1. **Create the Virtual Environment.** Install the chosen hypervisor on the host machine and create the five virtual machines described in Section 11.1, assigning each VM the hardware specifications listed in the corresponding configuration table.
2. **Deploy and Configure the Firewall.** Install pfSense and configure its three network interfaces using the static IP addressing scheme defined in Section 11.2. After verifying basic connectivity, configure the initial firewall policy to block all traffic from **Segment B** to **Segment C**, establishing the required network segmentation for the laboratory.
3. **Deploy the Web/FTP/SMB Server.** Install the Linux server designated for Segment A and configure the required network services. Deploy the vulnerable web login application, enable the **vsftpd** FTP service, and configure a **Samba** file share. Populate the server with the files, credentials, and challenge artifacts specified in Section 11.5.
4. **Configure the Internal Target Systems.** Install the two Linux target machines located in Segments B and C. Enable the **OpenSSH** service on both hosts, create the required user accounts, and place the hidden files, encrypted archives, and other laboratory artifacts in the locations defined in Section 11.5.
5. **Deploy the Attacker Machine.** Install Kali Linux as the attacker workstation in Segment A. Verify that it can communicate with the Web/FTP/SMB server

while confirming that access to the protected internal segments is correctly restricted by the pfSense firewall.

6. **Validate the Laboratory Workflow.** From the Kali VM, perform an initial service discovery scan (e.g., `nmap -sV 10.10.10.5`) to verify that the expected services on ports **21 (FTP)**, **80 (HTTP)**, and **445 (SMB)** are accessible. Then execute a complete end-to-end walkthrough of Stages 1–17 to confirm that every objective, flag, file placement, and network configuration functions as intended before distributing the laboratory to learners.
7. **Configure Optional Email Services.** If the laboratory includes a phishing or email delivery exercise, configure the mail server and publish the SPF record described in Section 11.3 to support realistic email delivery and validation.
8. **Create Baseline Snapshots.** After successfully validating the complete laboratory workflow, create a snapshot of each virtual machine. These snapshots provide a clean baseline, allowing the environment to be restored quickly between learner sessions and ensuring consistent, repeatable exercises.

12. Conclusion

This project set out to design and document a complete, self-contained Capture-The-Flag learning laboratory capable of introducing students and complete beginners to the full breadth of a realistic offensive-security engagement — from the first reconnaissance scan through to formal evidence reporting — in a format engaging enough to sustain motivation across seventeen distinct technical stages. The result is a platform that deliberately pairs a light, narrative-driven presentation layer with a rigorous, individually verified technical curriculum spanning network reconnaissance, web exploitation, social engineering, credential attacks, lateral movement, steganography, firewall administration, applied cryptography, open-source intelligence, digital forensics, and professional reporting.

The central design insight of this project is that gamification and technical rigour are not in tension with one another: by making every narrative beat depend on the successful completion of a genuine technical task, the laboratory ensures that engagement with the story is inseparable from engagement with the curriculum. Every credential a learner recovers, every file they extract, and every rule they modify is simultaneously a plot development and a verified demonstration of a real, transferable cybersecurity skill.

Looking ahead, the laboratory's modular, stage-based architecture lends itself naturally to future extension — additional branches covering cloud misconfiguration, mobile application security, or wireless attacks could be integrated using the same four-part content structure (lesson, real-world case, scenario, task) established across the existing seventeen stages, without requiring any change to the underlying instructional model. As it stands, the laboratory represents a complete, pedagogically grounded, and genuinely enjoyable introduction to practical cybersecurity for its intended beginner audience.

13. References

The following authoritative sources are referenced throughout the laboratory's individual stages as supplementary reading for learners, and were consulted in the preparation of this report:

- Nmap Project. Nmap Reference Guide. <https://nmap.org/book/man.html>
- IANA. Service Name and Transport Protocol Port Number Registry. <https://www.iana.org/assignments/service-names-port-numbers/service-names-port-numbers.xhtml>
- curl. curl Documentation. <https://curl.se/docs/>
- OWASP Foundation. Information Exposure Through HTML Comments. https://owasp.org/www-community/attacks/Information_disclosure
- Samba Team. smbclient Documentation. <https://www.samba.org/samba/docs/current/man-html/smbclient.1.html>
- Microsoft. SMB Protocol Overview. <https://learn.microsoft.com/en-us/windows-server/storage/file-server/file-server-smb-overview>
- OWASP Foundation. SQL Injection Prevention Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
- PortSwigger. Web Security Academy — SQL Injection. <https://portswigger.net/web-security/sql-injection>
- OWASP Foundation. OWASP Top Ten — A03:2021 Injection. https://owasp.org/Top10/A03_2021-Injection/
- OWASP Foundation. Credential Stuffing and Brute Force Guidance. https://owasp.org/www-community/attacks/Credential_stuffing
- NIST. Digital Identity Guidelines, SP 800-63B. <https://pages.nist.gov/800-63-3/sp800-63b.html>
- THC-Hydra Project. GitHub Repository. <https://github.com/vanhauser-thc/thc-hydra>
- IETF. RFC 959 — File Transfer Protocol. <https://www.rfc-editor.org/rfc/rfc959>

- CISA. Advisories on Insecure Protocol Configurations.
<https://www.cisa.gov/news-events/cybersecurity-advisories>
- steghide. Official Documentation.
<https://steghide.sourceforge.net/documentation.php>
- OpenSSH. Manual Pages (ssh, sftp). <https://www.openssh.com/manual.html>
- Netgate. pfSense Documentation.
<https://docs.netgate.com/pfsense/en/latest/>
- MITRE. ATT&CK — Exfiltration Over C2 Channel (T1041).
<https://attack.mitre.org/techniques/T1041/>
- CISA. Advisory AA20-352A — SolarWinds Supply Chain Compromise.
<https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a>
- Openwall. John the Ripper Documentation.
<https://www.openwall.com/john/doc/>
- GnuPG. Official Documentation. <https://www.gnupg.org/documentation/>
- NIST. FIPS 197 — Advanced Encryption Standard (AES).
<https://csrc.nist.gov/pubs/fips/197/final>
- Cloudflare. What Is AES Encryption?
<https://www.cloudflare.com/learning/ssl/what-is-encryption/>
- GNU Project. GNU tar Manual.
<https://www.gnu.org/software/tar/manual/tar.html>
- GNU Project. gzip Documentation.
<https://www.gnu.org/software/gzip/manual/gzip.html>
- SANS Institute. Digital Forensics and Incident Response White Papers.
<https://www.sans.org/white-papers/>